

Week 3 Project Deliverable

Defining ISMS Scope and Interested Parties for PaySphere

Project Area

ISO/IEC 27001 – ISMS Scope Definition and Interested Parties

1. Project Overview

As part of my self-curated Governance, Risk, and Compliance (GRC) Analyst curriculum, this Week 3 project focused on applying foundational Information Security Management System (ISMS) concepts to a simulated payment technology organization, **PaySphere**.

The objective of the project was to:

- Define clear organizational and operational boundaries for the ISMS.
- Identify which systems, functions, and activities are included within the ISMS scope.
- Explicitly identify out-of-scope systems and functions.
- Establish how third-party dependencies are addressed within the ISMS.
- Identify key interested parties.
- Document their security-relevant requirements.
- Define objective evidence that could demonstrate compliance with those requirements during an audit.

This exercise was designed to develop practical skills required for ISO 27001 implementation, internal audits, risk management, and GRC analyst roles.

2. Organization Scenario: PaySphere

PaySphere is a simulated payment processing organization that enables merchants to accept and process customer payments.

Its environment includes:

- A payment processing platform.
- Cloud-hosted infrastructure.
- Development and DevOps functions.
- Customer support operations.
- Third-party technology and service providers.
- Processing and handling of transaction and cardholder-related information.

Because PaySphere operates within the payments ecosystem, the organization must clearly understand which systems and business functions affect the confidentiality, integrity, and availability of payment and transaction data.

3. ISMS Scope Statement

Draft ISMS Scope

The Information Security Management System (ISMS) covers the design, development, and operation of PaySphere's payment processing platform, including PaySphere's cloud-hosted infrastructure, DevOps function, and customer support function, specifically where these systems and functions interact with cardholder or transaction data. Third-party services relied upon by PaySphere, including cloud infrastructure and external service providers, are addressed within the ISMS as external dependencies operating under documented contractual and shared-responsibility boundaries rather than as entities directly included within PaySphere's certification scope. Systems and functions that do not process, store, transmit, or directly support cardholder or transaction data, including marketing campaigns and marketing websites, are excluded from scope unless they are explicitly integrated with in-scope systems in the future.

4. Scope Boundary Analysis

A clearly defined ISMS scope is important because it establishes the boundaries of the organization's information security management activities.

For PaySphere, the primary scope principle is based on whether a system, function, or process:

- Processes cardholder data.
- Stores transaction-related information.
- Transmits payment-related information.
- Provides infrastructure or operational support to systems handling such information.
- Has direct integration with an in-scope payment processing system.

In-Scope Areas

The following functions and systems are considered within the ISMS scope:

- Payment processing platform.
- Design and development activities supporting the payment platform.
- Cloud-hosted infrastructure supporting the platform.
- DevOps activities responsible for deployment and operational support.
- Customer support functions where employees interact with cardholder or transaction-related information.

- Security and access management processes supporting in-scope systems.
- Third-party dependencies involved in processing, storing, transmitting, or supporting sensitive information.

Out-of-Scope Areas

The following are excluded unless they become integrated with in-scope systems:

- Standalone marketing campaigns.
- Marketing websites that do not process or interact with payment data.
- Systems that do not process, store, transmit, or directly support transaction or cardholder data.
- Business functions with no security dependency or integration with the payment processing environment.

Third-Party Boundary

An important distinction in ISMS scoping is that PaySphere's third-party providers are not automatically included as entities within PaySphere's ISMS.

For example, a cloud service provider's data centers and internal controls are not directly managed or certified by PaySphere.

Instead, PaySphere must manage:

- Its reliance on the third party.
- The data shared with the third party.
- Contractual security requirements.
- Shared-responsibility boundaries.
- Third-party risk.
- Security assurance and monitoring activities.

This distinction ensures that PaySphere can demonstrate accountability for the security risks associated with third-party dependencies without incorrectly representing external organizations as part of its own ISMS.

5. Interested Parties Analysis

Interested parties are individuals, organizations, or groups that have security-related requirements or expectations from PaySphere.

For this project, each interested party was analyzed using three factors:

1. **Who the interested party is.**
2. **What security-related requirement they have.**
3. **How PaySphere could provide objective evidence that the requirement is being met.**

Interested Parties Table

Interested Party	Security-Relevant Requirement	Evidence of Requirement Being Met
Merchants	Merchants require PaySphere to securely process payment transactions, protect transaction and cardholder information, maintain agreed service availability, and provide appropriate notification if a security incident affects their data or services.	Service availability and SLA reports, security incident records, merchant notification procedures, incident communication records, and relevant transaction monitoring evidence.
Regulators and Regulatory Bodies	Regulators require PaySphere to comply with applicable regulatory obligations, including data localization requirements, security and incident reporting obligations, and applicable timelines for notifying relevant authorities.	Data residency and cloud configuration evidence, incident response records, regulatory notification logs, reporting timestamps, compliance assessments, and documented regulatory procedures.
Investors and Business Stakeholders	Investors require assurance that information security risks are appropriately identified and managed to reduce the likelihood of significant financial, operational, legal, or reputational impact.	Risk registers, Key Risk Indicators (KRIs), security performance metrics, management review records, incident reports, business continuity metrics, and security risk reporting provided to management or stakeholders.
Employees	Employees require clearly defined responsibilities and appropriate access to systems and information necessary to perform their roles without unnecessary or excessive permissions.	Role-Based Access Control (RBAC) records, access review reports, access logs, segregation of duties documentation, MFA implementation evidence, onboarding and offboarding records, and information security policies.
Third-Party Vendors and Service Providers	Vendors that process, store, transmit, or support PaySphere data are required to protect that information according to agreed contractual and security requirements.	Vendor contracts and Data Processing Agreements (DPAs), security questionnaires, SOC reports or other independent assurance reports, ISO certifications where applicable, data flow documentation, vendor access records, and periodic third-party risk assessments.

6. Auditor Evidence Approach

A key objective of this project was to move beyond simply identifying stakeholders and their expectations.

In an ISO 27001 or GRC environment, identifying a requirement alone is not sufficient. An organization must also be able to demonstrate that the requirement is being addressed.

The evidence identified in this project follows the principle of **objective and auditable evidence**.

Examples include:

Technical Evidence

- System configuration records.
- Access logs.
- Data residency configurations.
- MFA implementation evidence.
- Transaction monitoring records.

Process Evidence

- Incident response records.
- Regulatory reporting logs.
- Access review documentation.
- Vendor assessment records.
- Management review records.

Governance Evidence

- Risk registers.
- Security policies.
- Third-party contracts.
- Data Processing Agreements.
- Key Risk Indicator reporting.
- Compliance assessment records.

This approach helps connect a stakeholder's requirement to a specific control, process, or documented artifact that can be reviewed during an audit.

7. Key Learning Outcomes

Through this project, I developed practical understanding of the following GRC and ISO 27001 concepts:

ISMS Scope Definition

I learned that an ISMS scope must clearly define organizational, technological, and operational boundaries. Broad statements such as "internal operations" are insufficient because an auditor should be able to identify exactly which systems, processes, teams, and activities are included.

Data-Based Scope Boundaries

The scope can be structured around a clear principle, such as whether a system processes, stores, transmits, or directly supports sensitive payment or transaction information.

This provides a repeatable method for determining whether new systems should be brought into scope.

Third-Party Dependencies

A third-party provider is not automatically part of an organization's ISMS simply because the organization uses its services.

The organization must instead manage the security risks associated with:

- The services provided.
- Data shared with the provider.
- Shared responsibilities.
- Contractual obligations.
- Assurance and monitoring activities.

Interested Parties vs. Controls

One of the key distinctions developed during this exercise was understanding the difference between:

Requirement:

What an interested party expects or needs from the organization.

Control:

What the organization implements to address that requirement.

Evidence:

What demonstrates to an auditor that the requirement or control is being fulfilled.

For example:

- An employee's requirement is appropriate access necessary to perform their role.
- RBAC and MFA are controls supporting that requirement.
- Access review reports and system logs provide evidence that the controls are operating.

This distinction is particularly important in GRC assessments and audit activities.

8. Conclusion

This project established a foundational ISMS scope and interested parties analysis for the simulated payment processing organization, PaySphere.

The final scope defines the systems, processes, functions, and third-party dependencies relevant to the protection of payment and transaction information while explicitly identifying activities that are outside the defined boundary.

The interested parties analysis connects stakeholder expectations with measurable and auditable evidence. This provides a practical foundation for future activities such as:

- Information security risk assessment.
- Control selection.
- Statement of Applicability development.
- Third-party risk management.
- Internal audits.
- ISO 27001 implementation activities.
- Compliance monitoring.

Overall, this deliverable demonstrates the ability to translate high-level ISO 27001 and GRC concepts into practical organizational boundaries, stakeholder requirements, and audit-ready evidence.